TEMPLATE P52 · ROOT CAUSE ANALYSIS AND CORRECTIVE ACTION PLAN

Root cause analysis and corrective action plan

Worksheet for finding the systemic cause of a nonconformity or an AI incident, analysing it without seeking to apportion blame and turning the conclusion into actions with an owner, a time limit and an effectiveness criterion.

Fernando García Varela Version 0.1 (working draft) 19-09-2026 Draft for review

IN THIS DOCUMENT

01 Instructions for use

02 Identification

03 Facts and timeline

04 Five whys

05 Cause-and-effect diagram (Ishikawa) (Enterprise)

06 Validation of the root cause

07 Blameless post-incident analysis

08 Corrective and preventive action plan

09 Effectiveness verification

10 Quality criteria

11 Approval and verification

12 Version control

Legal notice and disclaimer. SEVEN-G is a reference methodological framework provided "as is" and for information purposes only. It does not constitute legal, regulatory, financial or professional advice, nor does it guarantee compliance with any law or standard. References to general regulation (such as the EU AI Act, the GDPR, DORA or NIS2), to technical standards and to regulation specific to each sector or jurisdiction may be incomplete, may not apply to a particular case or may become out of date as a result of regulatory changes, interpretations or supervisory positions after their consultation date. **Each organisation that uses SEVEN-G is solely responsible for identifying the regulation that applies to it, verifying that it is current and certifying its own regulatory compliance**, with the appropriate qualified advice. This methodology is a generic, free aid shared with the community so that nobody has to start from scratch; each person or organisation can and should adapt it to its own use. It must not be inferred that its legally sensitive parts have been reviewed by legal counsel: those reviews, for each company or sector, are the ultimate responsibility of the company, consultant or organisation that uses it. Although every effort is made to keep it up to date, some regulation may have changed without being reflected here. To the fullest extent permitted by law, the author accepts no responsibility whatsoever for the effects of its application in any organisation or for its full applicability. The methodology does not grant certification of any kind. The author accepts no liability for any use made of this content or for any decisions taken on the basis of it. The data, figures, companies and cases in the examples are fictitious or illustrative.

Why it matters. Correcting the event without eliminating its cause guarantees that it will recur, in the same system or in another that shares a supplier, model or process. An analysis that ends in "human error" protects the management system and exposes people, and means that next time nobody reports in time. This worksheet sets the method, requires the root cause to meet four validity conditions and forces a decision on how the effectiveness of each action will be measured before it is executed; it is the evidence the AI Auditor needs to close a nonconformity (P50) and the post-incident analysis that closes an incident (P27).

01

Instructions for use

Aspect	Guidance
When it is used	Mandatory for major and critical nonconformities and for the post-incident analysis of S1, S2 and S3 incidents (simplified for S3); recommended for recurring minor nonconformities. Time limits: 37 §3.10 (nonconformities) and 37 §4.3 (post-incident analysis: 10 working days after technical closure for S1, 20 for S2, 30 days for S3).
Who completes it	The action owner (nonconformities) or the incident coordinator (incidents), with the technical team and the people who were involved. A facilitator from outside the team is advisable for S1 and critical nonconformities.
Who verifies it	The AI Risk Owner reviews the post-incident analysis of incidents (37 §4.5). The AI Auditor checks the validity of the root cause and the effectiveness before closing a nonconformity.
Who decides or approves	The plan is approved by the AI Committee (critical and S1), the AI Risk Owner (major and S2) or the AI Office (minor and S3), in accordance with 37 §3.6.
Stage, *gate* or moment	Phase 6 and any time a nonconformity is opened. It is reviewed at R6 (R6.06, R6.15), at G7 (G7.04) and in the C5 annual review (recurrences).
Tool	T08 · Nonconformity and incident register (actions and status). The worksheet is kept as linked evidence.
Reference document	Document 37 §2 (principles 4 and 6), §3.5–3.7 and §4.5 (phases 7 and 8); document 33 (materialised risks); document 35 (controls).
Lite versus Enterprise	Lite may use only the five whys and omit the blocks marked **(Enterprise)**. The validation of the root cause and the effectiveness criterion are mandatory in both.

Completion rules:

- **No blame, but clear accountability.** Causes are sought in the management system, not people to whom the failure can be attributed. "Human error" is not a final root cause: the question is why the system allowed that error or failed to detect it.
- Before the analysis starts, it is checked that the evidence from the time of the incident has been preserved (37 §2, principle 7).
- Several nonconformities with the same cause are analysed in a single worksheet, but each keeps its own code (37 §3.3).
- Every action considers whether the same failure exists in other systems or use cases (the "correct here and everywhere" principle).

02

Identification

Field	Content	Guidance
Subject of the analysis		NC-AAAA-NNN · INC-AAAA-NNN (one or several).
Type or severity		Minor · Major · Critical / S1 · S2 · S3 · S4.
System and use case		SIA-AAAA-NNN · IA-AAAA-NNN.
Facilitator		Role and name; from outside the team where advisable.
Participants		Roles, not just names.
Start date and deadline		In accordance with 37 §3.10 or §4.3.
Evidence preserved		Logs, model and instruction versions, configurations, inputs and outputs.
Worksheet version		

03

Facts and timeline

Verifiable facts are described, in order, without interpretation.

Date and time	Fact	Source or evidence	Who or what acted
(illustrative example) **03-11-2026 09:12**	The supplier's model version is replaced by a new one	Supplier change log	Supplier, without notifying the company
(illustrative example) **03-11-2026 15:40**	The rejection rate alert exceeds its threshold	Alert AL-04 in P25	Monitoring

Field	Content	Guidance
Immediate cause		What directly produced the event.

Field	Content	Guidance
What worked		Controls that detected or limited the harm.
What did not work		Controls that failed, did not exist or were not triggered.

04

Five whys

The question of why each answer occurred is asked until a cause is reached that can be acted upon and that explains the failure of the management system, not just the event. More or fewer than five steps may be needed.

Step	Question	Answer	Evidence
1	Why did the event occur?		
2	Why did the above occur?		
3	Why?		
4	Why?		
5	Why?		

(illustrative example) The assistant gave incorrect return periods → because the supplier changed the model version → because the contract did not require advance notice of version changes → because the supplier assessment did not review that clause → because P14 did not include it for N2 suppliers. Root cause: the list of clauses applied to N2 suppliers did not require advance notice of model changes.

05

Cause-and-effect diagram (Ishikawa) (**Enterprise**)

Possible causes are explored by category using the guiding questions in 37 §3.5. Only causes for which there are indications are recorded; those ruled out are marked with the reason.

Category	Guiding questions	Possible causes	Evidence	Confirmed? (Yes · No · Under analysis)
People and capabilities	Were they aware of the requirement? Did they have the training and the time? Was there pressure to move forward?			
Process and method	Was the requirement clear? Did the template or checklist include it? Did the workflow allow it to be skipped?			
Data	Did the data, its quality or its origin change? Was there lineage?			
Model and technology	Did the model, the instructions or the configuration change? Did monitoring fail?			
Suppliers	Were there unreported changes by the supplier? Did the contract cover this?			
Governance and controls	Was there segregation of duties? Was the control designed and tested? Did the register raise an alert?			
Environment	Did the regulation, the use or the volume change, or did an attacker appear?			

06

Validation of the root cause

Condition (37 §3.5)	Met? (Yes · No)	Justification
It explains all the facts observed.		
Had it been eliminated, the failure would not have occurred or would have been detected.		
It is actionable.		
It does not merely attribute responsibility to a person.		

Field	Content	Guidance
Confirmed root cause		One sentence. If there are several, they are numbered.
Was the risk in the register?		Yes (IA-AAAA-NNN · R*nn*, moves to *Materialised* and is reassessed, 33 §7.2) · No (it is added to P12).
Other systems or use cases exposed to the same cause		Same supplier, model, data, template or process.

07

Blameless post-incident analysis

For incidents only (37 §4.5, phase 7). It is completed in addition to sections 3 to 6.

Aspect	Content	Guidance
Effectiveness of detection		Hours between estimated start and detection; what would have brought it forward.
Effectiveness of containment		Hours between detection and containment; was the kill switch used and how long did it take to take effect?
Compliance with internal and regulatory time limits		In accordance with P51 §10.
Harm and cost		Amount and status (validated · declared · estimated), or *No data*.
Effectiveness of controls		SEG and AG controls that worked or failed.
Decisions taken under pressure		What information was missing and how the decision was made; without judging the people involved.
Lessons for other use cases (Enterprise)		Use cases with shared technology or suppliers to which they are communicated.
Should nonconformities be opened?		If the incident reveals a requirement not met or if the management breached the process (37 §6); NC codes opened in P50.

08

Corrective and preventive action plan

Type: Correction (remedy the event) · Corrective action (eliminate the root cause) · Preventive action (prevent the same cause from producing the failure in other systems). **Status:** Pending · In progress · Executed · Verified effective · Not effective.

No.	Cause addressed	Type	Action	Owner	Area with which it is agreed	Time limit	Effectiveness criterion	Expecte evidenc
A01								
A02								
A03								
***(illustrative example)* A01**	No advance notice of model changes	Corrective action	Add the advance notice clause to the N2 list in P14 and renegotiate the current contract	AI Technical Owner, with procurement	Legal counsel	31-01-2027	Contract signed with the clause; next version change notified in advance	Signed addendu supplier notice
***(illustrative example)* A02**	Same cause at other suppliers	Preventive action	Review the contracts of all N2 and N3 model suppliers	AI Office	Procurement	28-02-2027	100 % of contracts reviewed; those without the clause, with a plan	Review li

Field	Content	Guidance
Plan approved by		In accordance with 37 §3.6.
Approval date		The effectiveness criterion is fixed on this date.
Resulting updates		Risk register (P12), controls (P18), suppliers (P14), templates, test scenarios (P53).

09

Effectiveness verification

Action no.	Verification date	Period or sample observed	Result (Effective · Not effective)	Evidence	Verified by

If an action is not effective, the nonconformity returns to **Under analysis** (37 §3.7) and this worksheet is revised from section 6.

10

Quality criteria

Formal criteria in document 21 (R6.06, R6.15 and G7.04) and method in 37 §3.5–3.7.

#	Check	Status
1	The timeline is based on evidence preserved from the time of the event.	Met · Not met · Not applicable · Pending
2	The immediate cause is distinguished from the root cause.	
3	The root cause meets the four validity conditions and does not end in "human error".	
4	It has been checked whether other systems or use cases are exposed to the same cause.	
5	Each action has a type, an owner, a time limit, an effectiveness criterion and expected evidence.	
6	There is at least one corrective action for each root cause; correction alone is not enough.	
7	The risk register and the affected controls have been updated.	
8	Effectiveness has been verified with the criterion set when the plan was approved.	

11

Approval and verification

Function	Role in SEVEN-G	Name and position	Date	Signature or reference
Prepares	Action owner or incident coordinator			
Facilitates (Enterprise)	Person from outside the team			
Reviews the post-incident analysis	AI Risk Owner			
Approves the plan	AI Committee · AI Risk Owner · AI Office, according to type or severity			
Verifies effectiveness	AI Auditor (nonconformities) · AI Risk Owner (incident actions without a nonconformity)			

Segregation of duties: whoever gave rise to the event takes part by providing information, but does not validate the root cause or verify the effectiveness of the actions.

12

Version control

Completed document

Version	Date	Author	Changes

Template

Version	Date	Changes
0.1	19-09-2026	First version. Five whys, Ishikawa with the AI categories of 37 §3.5, validation of the root cause, blameless post-incident analysis, corrective and preventive action plan and effectiveness verification.